ĐỀ CƯƠNG ĐỒ ÁN

Tên đề tài: Xây dựng Website Chat Mã hóa Đầu cuối (E2E)

Sinh viên thực hiện: Nguyễn Trần Minh Hoàng – 22127130

1. MOTIVATION

Trong kỷ nguyên số, quyền riêng tư dữ liệu đang bị đe dọa nghiêm trọng bởi các cuộc tấn công mạng, nghe lén và việc thu thập dữ liệu trái phép từ các nhà cung cấp dịch vụ. Các ứng dụng nhắn tin truyền thống thường lưu trữ tin nhắn của người dùng dưới dạng văn bản rõ hoặc chỉ mã hóa đường truyền (HTTPS), điều này cho phép quản trị viên máy chủ hoặc tin tặc xâm nhập máy chủ có thể đọc được toàn bộ nội dung hội thoại.

Động lực nghiên cứu của đồ án là xây dựng một ứng dụng Web Chat mang tính cá nhân hóa, áp dụng mô hình mã hóa E2EE một cách minh bạch. Mục tiêu là tạo ra một môi trường giao tiếp an toàn, nơi tin nhắn văn bản chỉ có thể được giải mã trên thiết bị của người nhận, đảm bảo tính bí mật tuyệt đối ngay cả khi máy chủ trung gian bị tấn công.

2. OBJECTIVES

- **Mã hóa E2E:** Thực hiện giao thức trao đổi khóa an toàn dựa trên mô hình Diffie-Hellman hoặc Elliptic Curve Diffie-Hellman (ECDH) để thiết lập khóa phiên chung giữa hai người dùng.
- **Bảo mật tin nhắn văn bản:** Tin nhắn được mã hóa ngay tại trình duyệt của người gửi trước khi gửi lên máy chủ. Chỉ trình duyệt của người nhận mới có khả năng giải mã và hiển thị nội dung.
- **Quản lý danh tính an toàn:** Hệ thống xác thực người dùng mà không lưu trữ mật khẩu gốc, sử dụng cơ chế băm (Hashing). Khóa bí mật (Private Key) của người dùng được mã hóa bằng mật khẩu đăng nhập trước khi lưu trữ dưới dạng Encrypted Key Blob.
- **Giao diện người dùng:** Xây dựng giao diện web thân thiện, hỗ trợ nhắn tin thời gian thực (Real-time).

3. RELATED WORKS

- Tham khảo các tiêu chuẩn trao đổi key an toàn như Diffie-Hellman và Elliptic Curve Diffie-Hellman
- Áp dụng thuật toán mã hóa chuẩn (AES-GCM) theo các khuyến nghị mật mã hiện hành.
- Thiết kế hệ thống dựa trên nguyên tắc Zero-Knowledge, máy chủ không nắm giữ khóa bí mật.
- Kế thừa các best practices về quản lý và dẫn xuất khóa (PBKDF2, mã hóa khóa riêng).
- Tuân theo các tiêu chuẩn và tài liệu học thuật như OWASP ASVS và Web Crypto API.

4. CONTENT

4.1. Các chức năng chính (Functional Requirements)

1. **Secure Registration (Zero-Knowledge Key Architecture):**

   Áp dụng cơ chế Key Derivation phía client để tách mật khẩu thành hai khóa:

- **Authentication Key:** dùng để xác thực với máy chủ (máy chủ chỉ lưu giá trị băm).
- **Encryption Key:** dùng để mã hóa Private Key, chỉ tồn tại trong bộ nhớ trình duyệt.

Sinh cặp khóa bất đối xứng (RSA/ECDH), Private Key được mã hóa trước khi lưu trữ.

2. **Secure Login & Key Recovery:**

   Quá trình xác thực không gửi mật khẩu gốc qua đường truyền.

   Sau khi đăng nhập, client tải Encrypted Key Blob và giải mã bằng Encryption Key.

   Private Key được lưu tạm trong session để phục vụ giải mã tin nhắn.

3. **E2E Text Messaging:**

   Gửi tin: Người gửi lấy Pub Key của người nhận, tạo khóa chung, mã hóa tin nhắn và gửi qua Server

   Nhận tin: Người nhận sử dụng Private Key để tái tạo khóa chung và giải mã nội dung.

4.2. Yêu cầu phi chức năng

- **Performance:** Độ trễ gửi và nhận tin nhắn thấp hơn 200ms.
- **Security:**
  - Đảm bảo tính toàn vẹn dữ liệu (Integrity).
  - Chống các hình thức tấn công Replay Attack.

5. REFERENCES

1. Marlinspike, M., & Perrin, T. (2016). *The Double Ratchet Algorithm*. Signal Specifications.
2. OWASP Foundation. *OWASP Application Security Verification Standard (ASVS) 4.0 – Cryptography*.
3. MDN Web Docs. *Web Crypto API implementation*.

6. PROJECT PLAN

Kế hoạch thực hiện dự án 10 tuần, tuân thủ Waterfall, 5 giai đoạn – mỗi giai đoạn 2 tuần

Thời gian	Nội dung thực hiện
Tuần 1-2	Nghiên cứu bài toán Web Chat E2EE Xác định yêu cầu chức năng và phi chức năng Phân tích các tiêu chuẩn mật mã nền tảng
Tuần 3-4	Thiết kế kiến trúc tổng thể Client–Server Thiết kế luồng E2E Encryption và quản lý khóa Thiết kế CSDL và giao thức giao tiếp
Tuần 5-6	Xây dựng Frontend (UI, logic mã hóa/giải mã), Backend (WebSocket, API) Tích hợp Web Crypto API
Tuần 7-8	Kiểm thử chức năng chat E2EE, bảo mật (Zero-Knowledge, Replay Attack) Đánh giá hiệu năng hệ thống
Tuần 9-10	Hoàn thiện giao diện, tối ưu hệ thống và viết báo cáo đồ án